

ТЕХНОЛОГИЧЕСКАЯ ОЦЕНКА

Платформа автоматизации швейного производства

Аудит проведён: 28 мая 2026 г.

Стек: Next.js 16 + Prisma + SQLite + React

URL: <https://w1cem4d5ak91-d.space-z.ai/>

7

Критических
уязвимостей

12

Багов
бизнес-логики

6

Отсутствующих
функций

5

Рабочих
модулей

Общая оценка: 4/10 (требуется серьёзная доработка)

1. Общая оценка платформы

Платформа автоматизации швейного производства представляет собой веб-приложение, построенное на современном стеке технологий (Next.js 16, Prisma ORM, SQLite, React с TanStack Query). Приложение охватывает ключевые этапы швейного производства: от создания плана пошива до распределения готовой продукции по городам и коробам. Реализована ролевая модель доступа с девятью ролями (администратор, руководитель, швея, ОТК, закройщик, ВТО, технолог, селлер, заказчик).

С точки зрения технологической организации производства, платформа демонстрирует амбициозный охват бизнес-процессов, однако текущая реализация содержит ряд критических уязвимостей в безопасности, существенные ошибки в бизнес-логике и неполные функциональные модули. Положительными аспектами являются: корректная реализация потока статусов на уровне планов пошива, автоматическое создание раскройных планов при утверждении, поддержка комплектов с расширением цветов, а также наличие модуля учёта материалов с нормами расхода и автоматическим списанием при раскрое.

Основные проблемы можно разделить на три категории: (1) критические уязвимости безопасности, делающие систему непригодной для промышленной эксплуатации без доработки; (2) ошибки в бизнес-логике, приводящие к некорректным расчётам зарплат, потере данных о частичных сдачах и двойному учёту переделок; (3) неполные ролевые модули, где три из девяти ролей (технолог, закройщик, селлер) фактически не имеют функционального интерфейса. Ниже представлен детальный разбор каждого аспекта.

2. Безопасность (критический приоритет)

2.1. Уязвимости аутентификации

S1. Пароли хранятся в открытом виде

Пароли сотрудников хранятся в базе данных SQLite в виде открытого текста и сравниваются прямым равенством строк (`employee.password !== password`). Это означает, что любой человек с доступом к файлу базы данных может прочитать все пароли. Кроме того, API-эндпоинт `/api/employees` возвращает поле `password` в ответе, что делает пароли доступными через сетевой запрос без авторизации.

Для промышленной системы это абсолютно неприемлемо и является нарушением базовых принципов защиты данных.

- Решение: использовать bcrypt или argon2 для хеширования паролей; исключить поле password из API-ответов.

S2. Сессия на основе Base64 без подписи

Сессионный токен представляет собой Base64-кодированный JSON с данными пользователя (id, name, role). Токен не подписан и не зашифрован. Любой пользователь может декодировать токен, изменить поле role на "supervisor", закодировать обратно и получить полный административный доступ. Это полностью обесценивает ролевую модель безопасности, поскольку защита реализована только на уровне UI, а не на уровне сервера.

- Решение: подписывать токен HMAC-SHA256 или использовать JWT с серверным секретом.

S3. Cookie сессии не защищена

Сессионная cookie устанавливается с флагами httpOnly: false и secure: false. Это означает, что JavaScript на странице может прочитать и украсть токен (при наличии XSS-уязвимости), а токен передаётся в открытом виде по HTTP, что позволяет перехватить его через атаки типа man-in-the-middle. В сочетании с S2 это создаёт тройную уязвимость: токен можно прочитать, подделать и перехватить.

- Решение: установить httpOnly: true, secure: true, sameSite: "strict".

S4. Отсутствие авторизации на уровне API

Из 17 проверенных API-эндпоинтов ни один не требует аутентификации для операций чтения или записи. Любой неавторизованный пользователь может: создавать и удалять планы пошива, изменять раскройные планы, создавать швейные задания, добавлять и удалять материалы, управлять сотрудниками. Пользователь с ролью "швея" может через API создать план пошива, а заказчик может просмотреть данные всех сотрудников, включая пароли. Только эндпоинты /api/plans и /api/seller-plans проверяют роль для фильтрации по заказчику.

- Решение: добавить middleware авторизации ко всем API-маршрутам; проверять роль для каждой операции.

S5. localStorage как источник истины для роли

Auth-провайдер сохраняет данные пользователя в localStorage и использует их как fallback при недоступности сервера. Пользователь может вручную

изменить свою роль в localStorage, и UI будет отображать вкладки администратора. Хотя серверная часть в текущем состоянии также не проверяет роли, исправление S4 без устранения этого fallback-механизма создаст ложное ощущение безопасности.

- Решение: всегда получать роль с сервера; не доверять localStorage для авторизации.

#	Уязвимость	Критичность	Статус
S1	Пароли в открытом виде + утечка через API	CRITICAL	Не исправлено
S2	Сессия Base64 без подписи (подделка роли)	CRITICAL	Не исправлено
S3	Cookie без httpOnly/secure	CRITICAL	Не исправлено
S4	Нет авторизации на API (17 эндпоинтов открыты)	CRITICAL	Не исправлено
S5	localStorage как источник роли	HIGH	Не исправлено

3. Ошибки бизнес-логики

3.1. Критические ошибки потока статусов

B1. submitToQc полностью игнорируется API

Интерфейс швеи (SewerTab) отправляет данные с полем submitToQc для частичной сдачи изделий. Однако PATCH-обработчик /api/sewing-tasks/[id] извлекает только { status, items } - поле submitToQc молча отбрасывается. Это означает, что когда швея пытается сдать часть изделий (например, 30 из 50), эти данные теряются, и система не регистрирует частичную сдачу. Для производства, где пошив может растягиваться на несколько дней, это критический дефект - невозможно отследить промежуточный прогресс.

- Решение: реализовать обработку submitToQc в PATCH-обработчике; создавать отдельные записи для сданной и оставшейся частей.

B2. Несогласованность статусов задача-элементы

При установке статуса задачи в "pending_qc" через PATCH /api/sewing-tasks/[id], элементы задачи переводятся только в "pending_ironing", но не в "pending_qc". Возникает рассогласование: задача имеет статус "pending_qc", а её элементы

находятся в "pending_ironing". Оператор ВТО видит эти элементы и может отгладить их, но статус задачи уже говорит о том, что они прошли ВТО. Это приводит к путанице в производственном процессе и невозможности корректно отследить, на каком этапе находится заказ.

- Решение: при переводе задачи в "pending_qc" элементы должны проходить через ВТО, затем автоматически переходить в "pending_qc".

В3. Двойной учёт переделок в actualQuantity

Когда ОТК одобряет переделку (rework со статусом "completed"), количество переделанных единиц добавляется к actualQuantity элемента швейного задания. Однако эти единицы уже были учтены в actualQuantity при первоначальной сдаче швей. Таким образом, переделанные изделия учитываются дважды, что завышает показатели производства и, что более важно, завышает расчёт зарплаты швеи. Например, если швея сшила 100 изделий, из которых 10 отправлены на переделку и затем одобрены, система покажет actualQuantity = 110 вместо 100.

- Решение: при завершении переделки не добавлять количество к actualQuantity; вместо этого вести отдельный учёт переделок.

В4. Нет валидации переходов статусов

Отсутствует проверка порядка перехода статусов. Любой статус может быть установлен из любого другого. Ничто не мешает перевести задание из "issued" напрямую в "completed", минуя все промежуточные этапы, или вернуть из "completed" обратно в "issued". В реальном производстве это может привести к ситуациям, когда изделие отмечено как готовое, но фактически не прошло ни пошив, ни ВТО, ни контроль качества. Также возможен обратный переход, когда уже завершённое производство "откатывается" к начальной стадии.

- Решение: реализовать конечный автомат (state machine) с разрешёнными переходами; отклонять недопустимые переходы с кодом 400.

3.2. Ошибки модуля материалов

В5. Нет проверки достаточности материалов при раскрое

При маркировке раскройного плана как "cut" (раскроен), система автоматически списывает материалы через операцию decrement на поле totalQty. Однако если на складе недостаточно материала, decrement приведёт к отрицательному остатку (totalQty уйдёт ниже нуля). Нет предварительной проверки достаточности запасов. Раскройный план на 1000 изделий с нормой

200 г/шт потребует 200 кг ткани, даже если на складе всего 50 кг. Система молча создаст отрицательный остаток, который невозможно интерпретировать в реальном учёте. Это особенно опасно потому, что операция списания не обернута в транзакцию - при ошибке на середине операции данные останутся в неконсистентном состоянии.

- Решение: перед автосписанием проверять достаточность по каждому материалу; при нехватке возвращать ошибку с перечнем дефицита.

В6. Хрупкая защита от дублирования списания

Автосписание материалов проверяет наличие consumed-записей для раскройного плана. Если существует хотя бы одна такая запись (даже для другого материала), всё автосписание пропускается. Это означает, что при добавлении нового материала с нормой расхода после первого автосписания, новый материал не будет списан никогда. Защита от дублирования должна работать на уровне отдельных материалов, а не на уровне всего раскройного плана. В противном случае система будет накапливать расхождения между плановым и фактическим расходом материалов.

- Решение: проверять дублирование по паре (cuttingPlanId, materialId), а не только по cuttingPlanId.

В7. Агрессивное удаление остатков кроя

При уменьшении фактического количества до планового или ниже, система удаляет ВСЕ остатки кроя (CuttingLeftover), включая добавленные вручную с source="manual". Это уничтожает пользовательские данные, которые были введены целенаправленно. Ручные остатки могут представлять ценность - например, зарисовки на пустых участках ткани, которые планируется использовать для других заказов. Их удаление без предупреждения неприемлемо для производственного учёта.

- Решение: удалять только автоматически созданные остатки (source="cutting"); ручные остатки пометать, но не удалять.

3.3. Ошибки модуля ВТО и зарплат

В8. Зарплата ВТО по hardcoded ставке

Расчёт зарплаты утюжки использует константу IRONING_RATE = 10 рублей за единицу вместо продуктовой ставки product.ironingRate и размерных коэффициентов из ProductSizeRate. Поскольку разные изделия могут иметь существенно разные трудозатраты на утюжку (например, платье-макси и топка), плоская ставка приводит к несправедливой оплате труда. Кроме того,

система игнорирует размерные надбавки, которые уже реализованы в модели `ProductSizeRate`, но не используются при расчётах.

- Решение: использовать `product.ironingRate` с fallback на 10 руб.; применять размерные коэффициенты из `ProductSizeRate`.

B9. Нет привязки глажки к конкретному работнику

В модели `SewingTaskItem` отсутствует поле `ironedBy` (кто отгладил). Зарплата ВТО рассчитывается по всем изделиям в статусе "pending_qc" или "completed", без привязки к конкретному утюжилыщику. Если в смене работают несколько работников ВТО, невозможно определить, кто обработал какие изделия, и, соответственно, корректно рассчитать зарплату каждого. Это делает модуль зарплат ВТО непригодным для использования при наличии более одного работника.

- Решение: добавить поле `ironedBy` (String?) в `SewingTaskItem`; фиксировать работника при операции глажки.

B10. Переделки невидимы для ОТК

Когда переделка переходит в статус "pending_qc", родительское задание не обновляется. Оператор ОТК видит только задания в статусе "pending_qc", но переделка находится внутри завершённого задания и не видна в стандартном потоке. Для обнаружения переделок ОТК должен специально фильтровать по ним, что в текущем UI не реализовано. В результате переделанные изделия могут пройти весь цикл без повторного контроля качества, что недопустимо для производства, работающего с массовыми заказами.

- Решение: при переходе переделки в "pending_qc" обновлять родительское задание; добавить вкладку переделок в интерфейс ОТК.

B11. Нет валидации `actualQty` при раскрое

Раскройный план можно отметить как "раскроен" с нулевыми или отсутствующими значениями `actualQty`. Также нет проверки на отрицательные значения. Это позволяет создать раскройный план с фактическим количеством -5 или 0, что не имеет физического смысла. В сочетании с автоматическим созданием швейных заданий из раскройных позиций, это может привести к заданию с нулевым или отрицательным количеством изделий, что полностью ломает логику последующих этапов.

- Решение: требовать `actualQty > 0` для каждой позиции при маркировке "cut"; отклонять некорректные значения.

#	Ошибка	Модуль	Критичность
---	--------	--------	-------------

B1	submitToQc игнорируется API	Швейные задания	CRITICAL
B 2	Несогласованность статусов задача/элементы	Статусы	HIGH
B 3	Двойной учёт переделок	Зарплата	HIGH
B 4	Нет валидации переходов статусов	Статусы	HIGH
B 5	Отрицательный остаток материалов	Материалы	HIGH
B 6	Хрупкая защита от дублей списания	Материалы	MEDIUM
B 7	Удаление ручных остатков кроя	Раскрой	MEDIUM
B 8	Hardcoded ставка ВТО	Зарплата	MEDIUM
B 9	Нет привязки глажки к работнику	ВТО/Зарплата	MEDIUM
B1 0	Переделки невидимы для ОТК	ОТК	HIGH
B1 1	Нет валидации actualQty	Раскрой	MEDIUM

4. Целостность данных

Многошаговые операции, затрагивающие несколько записей в базе данных, не обернуты в транзакции Prisma. Это создаёт риск неконсистентного состояния данных при сбоях. Ниже перечислены операции, требующие транзакционной обёртки, но её не имеющие:

- Автосписание материалов при раскрое: создаёт несколько MaterialEntry и обновляет несколько Material без транзакции. Сбой на середине приведёт к частичному списанию.
- Утверждение плана: обновляет статус плана и создаёт раскройный план с позициями. При ошибке создания раскроя план останется "approved" без раскройного плана.
- Удаление швейного задания: удаляет переделки, элементы, затем само задание. Ошибка на середине оставит "сиротские" записи.

- Пакетная утюжка: обновляет несколько элементов и задач. Частичный сбой создаёт рассогласование статусов.
- Завершение переделки: обновляет переделку и модифицирует actualQuantity элемента. Неконсистентность при сбое второго шага.

Кроме того, паттерн "прочитать-изменить-записать" (read-modify-write) не является атомарным. Например, проверка существования consumed-записей перед автосписанием и последующее создание новых записей - это два отдельных запроса, между которыми может выполняться другой запрос, что приведёт к дублированию. Рекомендуется обернуть все многошаговые операции в `db.$transaction()` и добавить уникальные индексы для предотвращения дублирования на уровне базы данных.

5. Ролевая модель и UI

Система определяет девять ролей, но только пять из них имеют полноценный функционал. Три роли представлены заглушками ("Раздел в разработке"), а одна роль не имеет выделенного интерфейса. Это существенно ограничивает практическую применимость системы для реального производства.

Роль	UI-доступ	Функционал	Статус
Администратор	Все вкладки	Полное управление	LOW
Руководитель	Все вкладки	Мониторинг + управление	LOW
Швея	SewerTab	Задания, зарплата, тайминг	LOW
ОТК	QCTab	Приёмка, переделки	LOW
ВТО	IroningTab	Утюжка, зарплата	LOW
Заказчик	Планы + материалы	Просмотр балансов	LOW
Технолог	StubTab	Заглушка	HIGH
Закройщик	StubTab	Заглушка	HIGH
Селлер	Нет вкладки	Перенаправление	MEDIUM

Наиболее критичным является отсутствие интерфейса закройщика. Раскрой - один из ключевых этапов производства, но закройщик не может ввести

фактические количества, отметить дефекты ткани или управлять раскройными планами. Вся работа с раскроем сейчас выполняется через интерфейс администратора, что не соответствует реальному разделению труда на швейном производстве. Технолог также не имеет доступа к управлению нормами расхода материалов, аналитике производства и настройке технологических процессов - всё это делается через администратора.

6. Сильные стороны реализации

Несмотря на выявленные проблемы, платформа содержит ряд хорошо реализованных функциональных блоков, которые составляют прочную основу для дальнейшего развития. Ниже перечислены модули и механизмы, работающие корректно и соответствующие требованиям производственного учёта.

- **Поток статусов планов:** Последовательность `draft` - `approved` - `in_work` - `shipped` - `shipped_paid` реализована корректно с защитой от недопустимых операций (например, нельзя удалить утверждённый план).
- **Автоматическое создание раскроев:** При утверждении плана автоматически создаётся раскройный план с расширением комплектов (например, ч/б разбирается на чёрный и белый). Дополнительные раскройные планы получают метку "Дополнение 1".
- **Учёт материалов:** Полный цикл: CRUD для типов материалов, материалов, записей движения (`incoming/consumed`), норм расхода. Поддержка ручного добавления прихода и автоматического списания при раскрое.
- **Баланс материалов для заказчика:** Фильтрация по продуктам заказчика с контролем видимости через флаг `showMaterialBalance`. Заказчик видит только релевантные ему материалы.
- **Остатки кроя:** Автоматическое создание остатков при `actualQty > plannedQty`. Отдельный интерфейс управления остатками с пошаговым использованием.
- **Распределение по коробам:** Автоматическое распределение изделий по коробам с учётом вместимости. Поддержка типов коробов с размерными ограничителями.
- **Ролевой UI:** Каждая роль видит только релевантные вкладки. Швея не видит административных функций, ОТК не видит раскрой, заказчик видит только свои данные.

- **Тайминг операций:** Для каждого элемента швейного задания фиксируются метки времени: startedAt, ironedAt, qcAt, completedAt. Это позволяет анализировать производительность.
- **Приоритизация и дедлайны:** Планы пошива имеют поле priority (urgent/normal/low) и deadline. В UI отображаются бейджи приоритета и оставшееся время до дедлайна.
- **Фото изделий:** Загрузка изображений изделий через API /api/upload с поддержкой jpg/png/gif/webp до 5 МБ. Фото привязывается к карточке продукта.

7. План доработки по приоритетам

Ниже представлен план доработки, разделённый на четыре приоритетных уровня. Оценка трудозатрат указана в человеко-днях для одного разработчика. Рекомендуется выполнять доработки строго по приоритетам, начиная с критических, поскольку без устранения уязвимостей безопасности система не может быть использована в промышленной эксплуатации.

P0 - Критический (1-2 недели)

ID	Задача	Срок	Описание
P0. 1	Хеширование паролей (bcrypt)	2 дня	Заменить прямое сравнение на bcrypt.verify(); исключить password из API-ответов
P0. 2	Подпись сессионных токенов (HMAC-SHA256)	1 день	Подписывать Base64-токен HMAC; проверять подпись при каждом запросе
P0. 3	Защита cookie (httpOnly + secure)	0.5 дня	Установить httpOnly: true, secure: true, sameSite: strict
P0. 4	API-авторизация (middleware)	3 дня	Добавить проверку сессии и роли ко всем API-маршрутам
P0. 5	Исправить submitToQc (B1)	2 дня	Реализовать обработку частичной сдачи в PATCH /sewing-tasks/[id]
P0. 6	Проверка достаточности материалов (B5)	1 день	Предварительная проверка stock перед автосписанием; возврат ошибки при нехватке
P0. 7	Обёртка операций в транзакции	2 дня	Обернуть 5 критических многошаговых операций в db.\$transaction()

P1 - Высокий (2-3 недели)

ID	Задача	Срок	Описание
P1.1	Валидация переходов статусов (B4)	2 дня	Конечный автомат с разрешёнными переходами; отклонение невалидных с 400
P1.2	Согласованность задача/элементы (B2)	1 день	Корректный перевод элементов при смене статуса задачи
P1.3	Устранение двойного учёта переделок (B3)	1 день	Не добавлять rework.qty к actualQuantity при завершении переделки
P1.4	Переделки в интерфейсе ОТК (B10)	2 дня	Отдельная секция переделок на вкладке ОТК; обновление родительского задания
P1.5	Интерфейс закройщика	5 дней	Полноценная вкладка: раскройные планы, ввод actualQty, дефекты ткани
P1.6	Интерфейс технолога	5 дней	Нормы расхода, аналитика производства, настройка процессов
P1.7	Добавить ironedBy в SewingTaskItem (B9)	1 день	Новое поле + фиксация работника ВТО при операции глажки

P2 - Средний (3-4 недели)

ID	Задача	Срок	Описание
P2.1	Продуктовая ставка ВТО (B8)	1 день	Использовать product.ironingRate с размерными коэффициентами
P2.2	Защита от дублей списания (B6)	1 день	Проверка по (cuttingPlanId, materialId) вместо только cuttingPlanId
P2.3	Сохранение ручных остатков (B7)	0.5 дня	Удалять только source=cutting остатки; помечать manual
P2.4	Валидация actualQty (B11)	0.5 дня	Требовать actualQty > 0 при маркировке "cut"
P2.5	Резервирование материалов	3 дня	Бронирование при утверждении плана; автоматический расчёт потребности
P2.6	Оповещения о нехватке материалов	2 дня	Пороговые значения; уведомления на дашборде руководителя
P2.7	Аналитика производства	5 дней	Дашборд: среднее время по этапам, загрузка работников, дефектность

P3 - Низкий (по возможности)

ID	Задача	Срок	Описание
----	--------	------	----------

P3. 1	Интерфейс селлера	3 дня	Просмотр распределения по городам и коробам для своей территории
P3. 2	Конвертация единиц измерения	2 дня	Валидация совместимости единиц между нормами и материалами
P3. 3	Рефакторинг production-tabs.tsx	3 дня	Разделить 4700 строк на отдельные компоненты по вкладкам
P3. 4	Ограничения на уровне БД	1 день	CHECK-константы: totalQty >= 0, actualQty <= quantity и т.д.
P3. 5	Управление рулонами ткани	5 дней	Привязка раскроя к конкретным рулонам; учёт остатков на рулоне

8. Заключение

Платформа автоматизации швейного производства демонстрирует амбициозный замысел и охват ключевых бизнес-процессов швейного предприятия. Архитектурные решения (Next.js с серверными компонентами, Prisma ORM, ролевая модель) выбраны обоснованно и позволяют масштабировать систему. Реализованные модули - от создания планов пошива до распределения по коробам - образуют полный производственный цикл, что является весомым достижением для проекта текущего масштаба.

Однако текущее состояние системы не позволяет рекомендовать её к промышленной эксплуатации. Пять критических уязвимостей безопасности (открытые пароли, неподписанные сессии, отсутствие авторизации на API) делают систему уязвимой для злоумышленников и внутренних угроз. Одиннадцать ошибок бизнес-логики приводят к некорректным расчётам зарплат, потере данных о частичных сдачах и двойному учёту переделок. Три из девяти ролей не имеют функционального интерфейса.

При выполнении плана доработки P0 (критический приоритет, ориентировочно 1-2 недели) система перейдёт из состояния "непригодна" в "минимально жизнеспособна". Выполнение P1 (высокий приоритет, ещё 2-3 недели) позволит полноценно использовать систему на производстве с полным набором ролей и корректной бизнес-логикой. Рекомендую приоритезировать безопасность и целостность данных над добавлением нового функционала - без фундамента надстройка будет ненадёжной.